[Logo oficial UMG — insertar]

UNIVERSIDAD MARIANO GÁLVEZ DE GUATEMALA

Maestría en Seguridad Informática

Curso: Seguridad en Aplicaciones

Laboratorio de Seguridad de Aplicaciones sobre OWASP Juice Shop

Fase 6: Operaciones, Monitoreo y Ciberseguridad

Integrantes:

Molina Pérez, Juan Carlos

Sánchez Flores, Juan Walter Ernesto

García Gonzalez, Leopoldo Emanuel

Cambara Castillo, Vanessa Odeth

Catedrático: Ing. Matthew Alexander Seigne Samayoa

Guatemala, noviembre de 2026

Índice

Introducción....3

Objetivos....3

1. Estrategia de Mitigación y Ciberseguridad....5

1.1 Arquitectura operativa y defensa en profundidad....5

1.2 Controles compensatorios por riesgo....6

1.3 WAF: reglas para bloquear el OWASP Top 10:2025....7

1.4 RASP y monitoreo de APIs en tiempo de ejecución....9

1.5 SIEM: centralización de logs de auditoría....12

1.6 Verificación integral de los controles....15

2. Tratamiento Formal del Riesgo....17

2.1 Método de valoración reproducible....17

2.2 Opciones de tratamiento....17

2.3 Categorización del riesgo por tipo e impacto....18

2.4 Matriz de decisiones por riesgo....19

2.5 Matriz de calor: probabilidad frente a impacto....20

2.6 Lectura del riesgo residual....22

Limitaciones y trabajo futuro....24

Conclusiones....24

Referencias....26

Anexos....27

Introducción

El presente documento recopila la evidencia de la Fase 6 del laboratorio de Seguridad de Aplicaciones desarrollado sobre OWASP Juice Shop versión 20.3.0. Esta fase traslada los hallazgos de las fases de ciberdefensa (Fases 4 y 5) al plano de las **operaciones**: define controles compensatorios para cada riesgo, los integra en un entorno ejecutable y verifica, con pruebas repetibles, qué protegen realmente y qué no. Los componentes operativos son un cortafuegos de aplicaciones web (WAF), una protección en tiempo de ejecución dentro de la aplicación (RASP) con monitoreo de API, y un sistema de gestión de eventos (SIEM) que centraliza los registros de auditoría y genera alertas.

La segunda parte formaliza el **tratamiento del riesgo** siguiendo ISO/IEC 27005: cada riesgo se categoriza por tipo e impacto, recibe una decisión (aceptar, eliminar, evitar, mitigar o transferir) y se representa en una matriz de calor de probabilidad frente a impacto antes y después de los controles. Para evitar valoraciones arbitrarias, la probabilidad y el impacto se derivan del análisis DREAD de la Fase 1 mediante un procedimiento reproducible, y solo los controles **verificados con evidencia** reducen el riesgo residual.

Todas las pruebas se ejecutaron bajo las reglas de aislamiento del laboratorio: los servicios solo escucharon en la dirección de bucle local (127.0.0.1) o en redes internas de Docker, únicamente se evaluaron instancias propias y ningún componente envió telemetría a servicios externos. Cada resultado remite a archivos de evidencia cuyo hash SHA-256 figura en el manifiesto del repositorio (Anexo A) y a la bitácora de comandos (Anexo B).

Repositorio del proyecto: https://github.com/jmolinap1-universidad/juice-shop-lab

Objetivos

Objetivo general

Operar la aplicación endurecida con controles de ciberseguridad en capas —perímetro, ejecución y monitoreo— y tratar formalmente cada riesgo identificado,

demostrando con evidencia verificable la reducción del riesgo inherente al riesgo residual.

Objetivos específicos

- Definir un control compensatorio para cada riesgo identificado en las fases de ciberdefensa, indicando su tipo, estado y evidencia.
- Configurar un WAF con reglas que cubran el OWASP Top 10:2025 y verificar su efecto sin bloquear el tráfico legítimo.
- Integrar un RASP y reglas de monitoreo de API que detecten comportamientos anómalos en tiempo de ejecución.
- Centralizar los registros de auditoría en un SIEM con reglas de correlación y alerta.
- Construir la matriz de decisiones de tratamiento, la categorización por tipo e impacto y las matrices de calor antes y después de los controles.

1. Estrategia de Mitigación y Ciberseguridad

La estrategia aplica defensa en profundidad: ningún control se considera suficiente por sí mismo. El WAF filtra en el perímetro; el RASP vigila dentro de la aplicación las operaciones peligrosas (consultas a la base de datos, acceso a archivos, llamadas de red); el endurecimiento del contenedor de la Fase 5 contiene el daño si algo se ejecuta; y el SIEM observa todas las capas para detectar lo que las demás no bloquean. La capa de operaciones se añadió como un archivo de Compose adicional, sin modificar la configuración auditada en la Fase 5.

1.1 Arquitectura operativa y defensa en profundidad

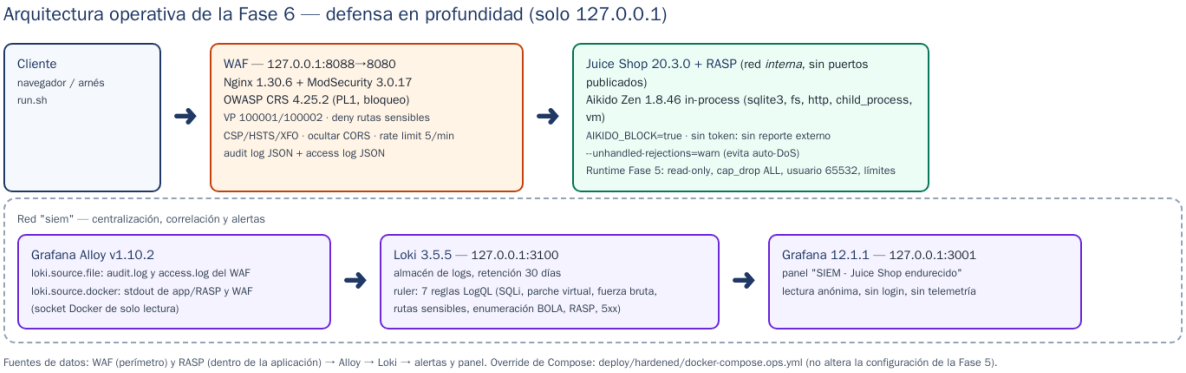


Figura 1. *Arquitectura operativa de la Fase 6: WAF en el perímetro, aplicación con RASP en una red interna sin puertos publicados y SIEM (Alloy, Loki y Grafana) en una red propia; todo expuesto solo en 127.0.0.1.*

El entorno se levanta con `make ops-up` (equivalente a `docker compose -f docker-compose.yml -f docker-compose.ops.yml up -d --build` en `deploy/hardened/`). En esta ejecución el WAF se publicó en `127.0.0.1:8088` porque el puerto 8080 estaba ocupado por un proceso Java del equipo; no se interrumpió ese proceso y el puerto quedó parametrizado (`WAF_PORT`). Ningún componente reporta a terceros: el RASP se ejecuta sin token de su proveedor (registra «No token provided, disabling reporting»), Loki y Alloy tienen la telemetría desactivada y Grafana se sirve en solo lectura, sin formulario de inicio de sesión.

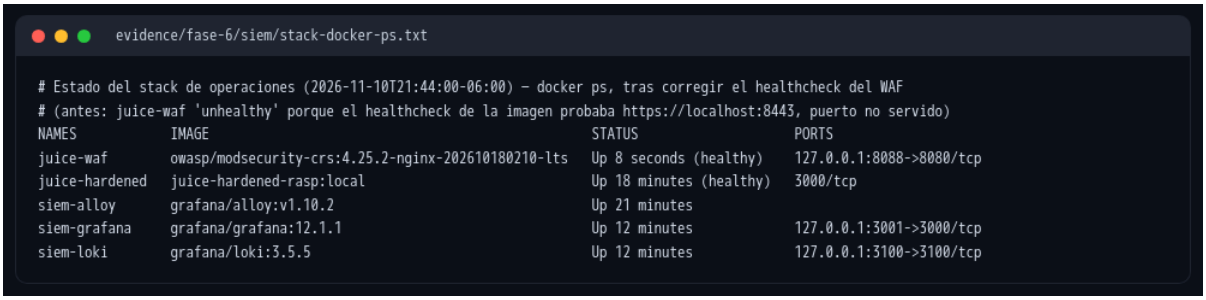


Figura 2. *Estado de los cinco contenedores del entorno de operaciones (docker ps): WAF y aplicación con RASP en estado healthy; Loki (3100) y Grafana (3001) publicados solo en 127.0.0.1.*

Durante la puesta en marcha se detectó y corrigió un fallo operativo heredado: el healthcheck de la imagen del WAF consulta https://localhost:8443/healthz, pero la plantilla del laboratorio solo sirve HTTP en el puerto 8080, por lo que el contenedor figuraba como **unhealthy** aunque filtraba correctamente. Un orquestador lo habría reiniciado o retirado de servicio. Se reemplazó por una comprobación HTTP sobre el mismo endpoint /healthz, y el estado pasó a healthy sin cambios en el tráfico (Figura 2).

1.2 Controles compensatorios por riesgo

Para cada uno de los 24 riesgos del registro (Sección 2) se definió al menos un control, clasificado por tipo —preventivo, detectivo, de contención, de eliminación, de evitación o de transferencia— y por estado: **verificado** (con evidencia en el repositorio), **diseñado** (corrección validada como diff con git apply --check, no desplegada) o **propuesto**. La Tabla 1 resume el control compensatorio principal por riesgo; el detalle completo con todas las evidencias está en el Anexo D.

Tabla 1

Control compensatorio principal por riesgo y estado

ID	Riesgo	Control compensatorio principal	Tipo	Estado
R01	Inyección SQL en el login (bypass de autenticación)	WAF ModSecurity + CRS 942xxx (bloqueo 403)	preventivo	Verificado
R02	Inyección SQL UNION en búsqueda (extracción de tablas)	WAF ModSecurity + CRS 942xxx (bloqueo 403)	preventivo	Verificado
R03	Clave privada JWT embebida en el código (forja de tokens)	Parche 04: clave fuera del código (variable/secreto)	eliminacion	Diseñado (diff validado)
R04	Bibliotecas JWT obsoletas (algoritmos débiles)	SCA en CI (npm audit, OSV, Grype) que alerta del componente	detectivo	Verificado
R05	Contraseñas con MD5 sin sal	Bloqueo de la vía principal de extracción de hashes (SQLi: WAF + RASP)	preventivo	Verificado
R06	BOLA/IDOR: lectura de recursos de otro usuario	Monitoreo de API: alerta API_Enumeracion_Objetos_PosibleBOLA	detectivo	Verificado
R07	Asignación masiva de role=admin en el registro	Parche virtual ModSecurity 100001	preventivo	Verificado

ID	Riesgo	Control compensatorio principal	Tipo	Estado
R08	Inyección NoSQL en reseñas (MarsDB)	Rechazar operadores ($ne, $where...) en filtros	eliminacion	Propuesto
R09	Ejecución de código via eval()/vm	Contención: FS solo lectura, cap_drop ALL, no root, no-new-privileges	contencion	Verificado
R10	XXE en la carga de XML	Parser XML sin entidades externas ni DTD	eliminacion	Propuesto
R11	SSRF en la imagen de perfil por URL	Lista blanca de destinos y filtrado de egreso	preventivo	Propuesto
R12	Listado de directorios y archivos internos (/ftp, /encryptionkeys)	nginx deny de rutas sensibles (403)	preventivo	Verificado
R13	XSS (CSP debil, sin codificación de salida)	CSP estricta (script-src 'self') y cabeceras en el WAF	preventivo	Verificado
R14	CORS permisivo (ACAO *)	WAF oculta Access-Control-Allow-Origin	preventivo	Verificado
R15	Redirección abierta (lista blanca evadible)	Comparación exacta de destinos permitidos	eliminacion	Propuesto
R16	Fuerza bruta en el login (sin limitación de intentos)	Rate limiting nginx 5/min (HTTP 429)	preventivo	Verificado
R17	/metrics expuesto sin autenticación	nginx deny /metrics (403)	preventivo	Verificado
R18	Denegación de servicio por vm/ZIP (agotamiento de recursos)	Límites de pids (200), memoria (1 GiB) y CPU (1.0)	contencion	Verificado
R19	Registro sin centralización ni alertas	Alertas activas verificadas (6/7 en firing durante las pruebas)	detectivo	Verificado
R20	Dependencias con CVE criticas (cadena de suministro)	SCA en CI (npm audit, OSV, Grype, Trivy) en cada push	detectivo	Verificado
R21	Configuración insegura al desplegar la arquitectura cloud (AWS)	Checkov sobre Terraform (144 passed / 0 failed)	preventivo	Verificado
R22	RASP en modo bloqueo provoca la caída del proceso (auto-DoS)	Node --unhandled-rejections=warn (proceso sin caídas, RestartCount 0)	eliminacion	Verificado
R23	Exposición de datos personales (incumplimiento de protección de datos)	Bloqueo de la extracción masiva por SQLi (WAF + RASP)	preventivo	Verificado
R24	SIEM de un solo nodo (sin alta disponibilidad; agente con acceso al socket de Docker)	Solo 127.0.0.1, socket de solo lectura, retención 30 dias, sin telemetría externa	contencion	Verificado

Nota. Elaboración propia con datos del repositorio del laboratorio.

Los riesgos cuyo único control está diseñado o propuesto (por ejemplo R03, clave privada JWT embebida; R08, inyección NoSQL; R10, XXE) no tienen hoy un control compensatorio efectivo desplegado; se mantienen así en el registro para no sobrestimar la protección.

1.3 WAF: reglas para bloquear el OWASP Top 10:2025

El WAF combina Nginx 1.30.6, ModSecurity 3.0.17 y el OWASP Core Rule Set (CRS) 4.25.2 en nivel de paranoia 1, en modo de bloqueo y con puntuación de anomalía (umbral entrante 5, saliente 4). Sobre el CRS se añadieron controles propios: dos parches virtuales (100001, asignación masiva del rol en el registro; 100002, endpoint /metrics), denegación de rutas internas, cabeceras de seguridad, ocultación del CORS

permisivo de la aplicación y limitación de tasa del inicio de sesión. La Figura 3 muestra el inventario real de reglas cargadas, extraído del contenedor en ejecución.



evidence/fase-6/waf/crs-inventario.txt

```
# Inventario de reglas del WAF desplegado (Fase 6) — 2026-11-10T21:32:48-06:00
# Imagen: owasp/modsecurity-crs:4.25.2-nginx-202610180210-lts (contenedor juice-waf en ejecución)
# Formato: archivo|reglas con id
REQUEST-901-INITIALIZATION.conf|36
REQUEST-905-COMMON-EXCEPTIONS.conf|2
REQUEST-911-METHOD-ENFORCEMENT.conf|9
REQUEST-913-SCANNER-DETECTION.conf|9
REQUEST-920-PROTOCOL-ENFORCEMENT.conf|68
REQUEST-921-PROTOCOL-ATTACK.conf|26
REQUEST-922-MULTIPART-ATTACK.conf|7
REQUEST-930-APPLICATION-ATTACK-LFI.conf|14
REQUEST-931-APPLICATION-ATTACK-RFI.conf|13
REQUEST-932-APPLICATION-ATTACK-RCE.conf|55
REQUEST-933-APPLICATION-ATTACK-PHP.conf|29
REQUEST-934-APPLICATION-ATTACK-GENERIC.conf|19
REQUEST-941-APPLICATION-ATTACK-XSS.conf|42
REQUEST-942-APPLICATION-ATTACK-SQLI.conf|68
REQUEST-943-APPLICATION-ATTACK-SESSION-FIXATION.conf|11
REQUEST-944-APPLICATION-ATTACK-JAVA.conf|22
REQUEST-949-BLOCKING-EVALUATION.conf|28
REQUEST-999-COMMON-EXCEPTIONS-AFTER.conf|0
REQUEST-999-VIRTUAL-PATCHES.conf|2
RESPONSE-950-DATA-LEAKAGES.conf|15
RESPONSE-951-DATA-LEAKAGES-SQL.conf|26
RESPONSE-952-DATA-LEAKAGES-JAVA.conf|10
RESPONSE-953-DATA-LEAKAGES-PHP.conf|13
RESPONSE-954-DATA-LEAKAGES-IIS.conf|14
RESPONSE-955-WEB-SHELLS.conf|36
RESPONSE-956-DATA-LEAKAGES-RUBY.conf|11
RESPONSE-959-BLOCKING-EVALUATION.conf|28
RESPONSE-980-CORRELATION.conf|21

# Configuración efectiva relevante (variables del contenedor)
ANOMALY_INBOUND=5
ANOMALY_OUTBOUND=4
BLOCKING_PARANOIA=1
MODSEC_AUDIT_ENGINE=RelevantOnly
MODSEC_AUDIT_LOG_FORMAT=JSON
MODSEC_RULE_ENGINE=On
PARANOIA=1

# Versiones
nginx version: nginx/1.30.6
CRS: OWASP_CRS/4.25.2 (campo components del audit log; la cadena 3.1.0 del archivo de inicializacion es una referencia heredada, no la version)
ModSecurity: v3.0.17 (campo producer del audit log)

# Parches virtuales propios cargados
id:100001
id:100002
```

Figura 3. *Inventario de reglas del WAF desplegado: número de reglas por familia del CRS, configuración efectiva (paranoia, umbrales, motor) y parches virtuales propios cargados.*

Tabla 2

Cobertura del OWASP Top 10:2025 por los controles del WAF

OWASP Top 10:2025	Control en el WAF	Reglas	Verificación
A01 Broken Access Control	Deny de rutas internas; VP 100001; CRS 930/931 (LFI/RFI)	27	Rutas y VP bloquean (403). El BOLA NO es bloqueable por un WAF (verificado)
A02 Security Misconfiguration	Cabeceras; ocultar CORS; deny /metrics + VP 100002; CRS 920/921, 913	103	Cabeceras, CORS y /metrics verificados; CRS 920 activo
A03 Software Supply Chain Failures	— (no es función del WAF)	—	SCA en CI (Fase 3)

OWASP Top 10:2025	Control en el WAF	Reglas	Verificación
A04 Cryptographic Failures	HSTS; CRS 950-956 (fugas en respuestas)	125	HSTS presente; 95x sin eventos
A05 Injection	CRS 942 (SQLi), 941 (XSS), 932 (RCE), 934 (genérica, Node.js), 943	195	CRS 942 bloqueó las 3 SQLi
A06 Insecure Design	— (diseño)	—	Modelado de amenazas y parches
A07 Authentication Failures	limit_req 5/min, ráfaga 3 en el login (429)	—	8 respuestas 429
A08 Software or Data Integrity Failures	—	—	No aplica al WAF
A09 Security Logging and Alerting Failures	Audit log y access log en JSON hacia el SIEM	—	Ingestado en Loki (1.5)
A10 Mishandling of Exceptional Conditions	CRS 920 (peticiones malformadas); alerta de 5xx	68	Configurado; sin ráfagas 5xx

Nota. Elaboración propia con datos del repositorio del laboratorio.

La columna «Reglas» suma las reglas con identificador de las familias del CRS indicadas (Figura 3). Se identificó además **ruido operativo**: la regla 920350 («Host header is a numeric IP address») se activa en casi todas las peticiones porque el laboratorio se accede por IP. Es de severidad *warning* y no bloquea por sí sola, pero consume margen del umbral de anomalía; con un nombre de dominio desaparece. Se propone excluirla en el laboratorio (`SecRuleRemoveById 920350`) como ajuste fino, sin aplicarlo en esta entrega para no alterar la configuración medida.

1.4 RASP y monitoreo de APIs en tiempo de ejecución

Como RASP se integró **Aikido Zen 1.8.46**, un agente de código abierto (licencia AGPL-3.0) que se carga dentro del proceso Node.js e instrumenta los puntos donde un ataque produce efecto: el controlador `sqlite3`, el sistema de archivos, la ejecución de procesos, las peticiones HTTP salientes y `node:vm`. Se incorporó sin modificar el código de Juice Shop, con un Dockerfile que copia el agente sobre la imagen oficial fijada por digest y lo precarga mediante `NODE_OPTIONS=--require @aikidosec/firewall`. Tiene dos modos: monitoreo (`AIKIDO_BLOCK=false`, detecta y registra) y bloqueo (`AIKIDO_BLOCK=true`).

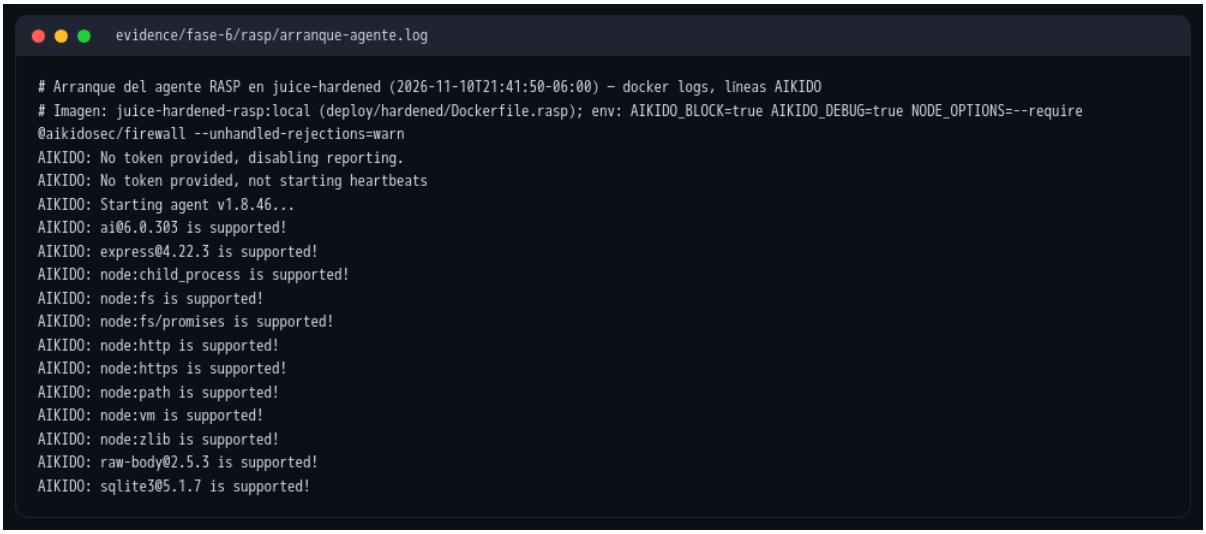


Figura 4. *Arranque del agente RASP: sin token no hay reporte externo; se confirman como soportados sqlite3 5.1.7, Express 4.22.3 y los módulos de Node instrumentados.*

Para medir el RASP **aislado del WAF** se ejecutó el mismo arnés de la Fase 4 (security/attacks/run.sh) desde la red interna de Docker directamente contra la aplicación, lo que simula que el perímetro fue evadido. Se realizaron tres corridas (Tabla 3).

Tabla 3

Corridas del RASP sin WAF delante

Corrida	Configuración	Resultado	Evidencia
1	Monitoreo (AIKIDO_BLOCK=false)	3 SQLi detectadas (body.email; query.q ×2) en sqlite3.all; no se bloquean (esperado)	evidence/fase-6/rasp/01-deteccion-sin-bloqueo/
2	Bloqueo con la configuración por defecto	El primer bloqueo terminó el proceso Node (RestartCount=1). Corrida inválida para medir mitigación (HTTP 000)	evidence/fase-6/rasp/02-bloqueo-caida-del-proceso/
3	Bloqueo + --unhandled-rejections=warn	A1-A3 bloqueadas en el sink sin caídas (RestartCount 0); A4-A12 siguen vulnerables sin WAF (fuera del alcance del RASP)	evidence/fase-6/rasp/03-bloqueo-sin-caida/

Nota. Elaboración propia con datos del repositorio del laboratorio.

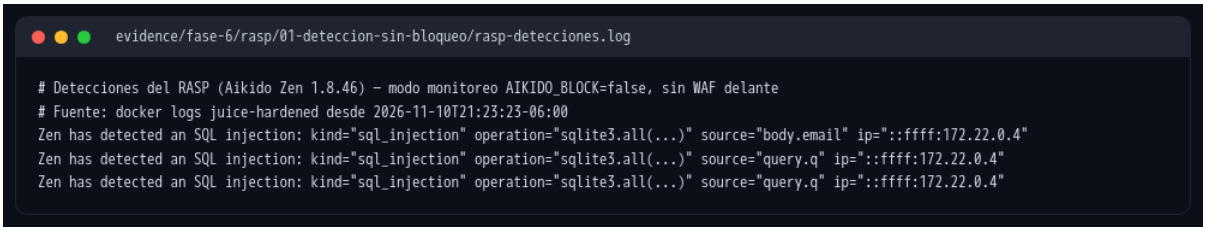


Figura 5. *Corrida 1, modo monitoreo: el RASP detecta las tres inyecciones SQL indicando operación (sqlite3.all), origen del dato (body.email, query.q) e IP.*

La corrida 2 reveló un **hallazgo operativo** relevante. En modo bloqueo, el agente lanza un error dentro de Sequelize que queda como rechazo de promesa no manejado

y, con la configuración predeterminada de Node.js 24, termina el proceso. Cada intento de inyección detectado se convertía así en una caída del servicio: un atacante podía usar el propio control como vector de denegación de servicio (OWASP A10:2025, CWE-248/755). Los resultados de esa corrida no se usan como mitigación: tras la caída, las peticiones obtuvieron HTTP 000 (conexión rechazada), que el arnés interpreta como ausencia de datos. La carpeta se conservó y se marcó como inválida.

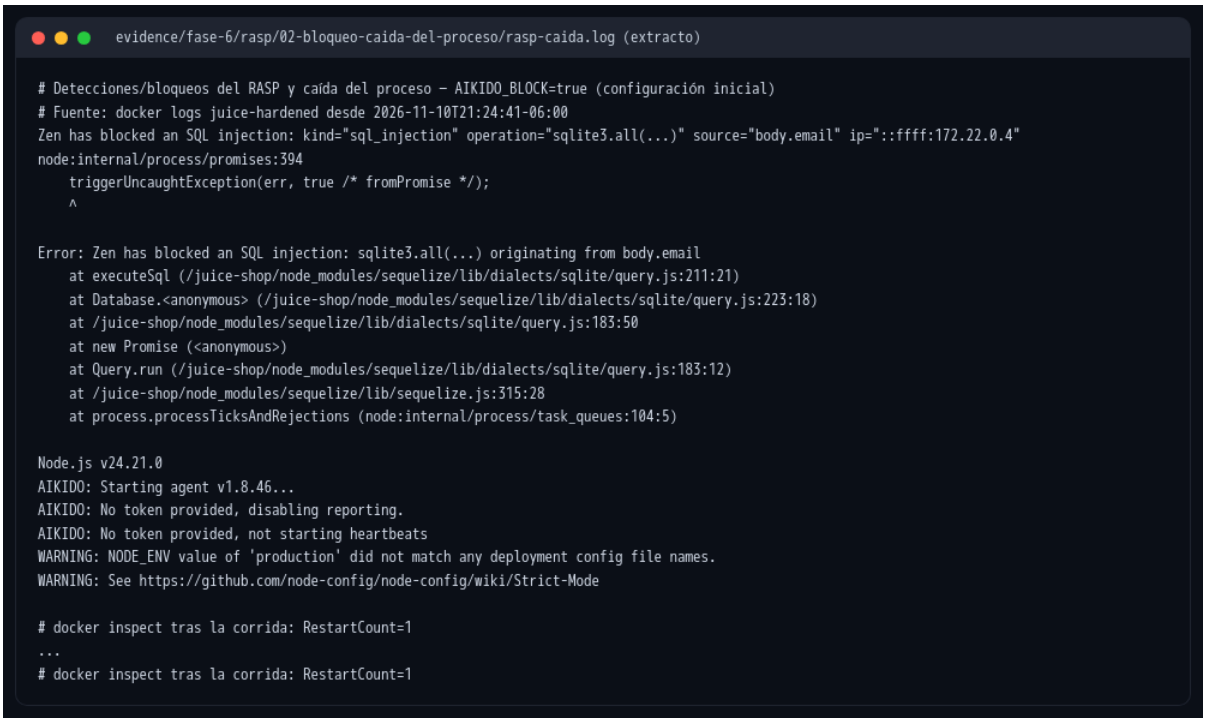


Figura 6. *Corrida 2 (extracto): bloqueo de la inyección en body.email seguido de la excepción no manejada que termina el proceso y del reinicio del agente.*

El riesgo se trató con la decisión **Eliminar**: se configuró --unhandled-rejections=warn, de modo que el error queda registrado sin terminar el proceso. La corrida 3 confirmó el bloqueo de A1-A3 en el sink con RestartCount igual a 0. Como efecto residual, la petición bloqueada se queda sin respuesta mientras el resto del servicio sigue operativo; la integración definitiva consistiría en capturar el error en la capa de datos y responder 403.



Figura 7. *Corrida 3: el RASP bloquea las tres inyecciones (body.email y query.q) sin caída del proceso; RestartCount = 0.*

El **alcance real del RASP** es la inyección en los sinks instrumentados. No cubre exposiciones de configuración (listados, /metrics), asignación masiva, ausencia de rate limit ni BOLA (su protección IDOR requiere integrar el identificador de inquilino en el código), y solo soporta inyección NoSQL en MongoDB, no en MarsDB. Por eso es una capa adicional y no sustituye al WAF ni a la corrección del código.

El **monitoreo de API** se implementó como reglas de correlación sobre el registro de acceso del WAF, que en formato JSON no incluye cabeceras de autorización ni cuerpos. La regla API_Enumeracion_Objetos_PosibleBOLA alerta cuando se consultan dos o más cestas distintas en cinco minutos y es el control **detectivo** del BOLA que el WAF no puede bloquear. Login_FuerzaBruta_RateLimit vigila las ráfagas 429 y App_Errores_5xx las tasas anómalas de errores. Limitación del laboratorio: todo el tráfico llega desde la IP de la pasarela de Docker, por lo que la correlación es global; en producción se agruparía por cliente o usuario.

1.5 SIEM: centralización de logs de auditoría

El SIEM se construyó con la pila de Grafana: **Alloy v1.10.2** recolecta los registros, **Loki 3.5.5** los almacena (retención de 30 días) y evalúa las reglas de correlación cada 15 segundos, y **Grafana 12.1.1** presenta el panel de seguridad. Las fuentes son el audit log de ModSecurity (una transacción JSON por línea), el registro de acceso JSON del WAF y la salida estándar de la aplicación y del WAF, que incluye las detecciones del RASP.

Tabla 4

Reglas de correlación y alerta del SIEM y su estado durante las pruebas

Regla	Lógica (ventana de 5 min)	Riesgo	Estado
WAF_InyeccionSQL_Bloqueada	Eventos CRS 942xxx > 0	R01, R02	firing
WAF_ParcheVirtual_Activado	Reglas 10000x > 0	R07, R17	firing
Login_FuerzaBruta_RateLimit	≥ 3 respuestas 429	R16	firing
Acceso_Rutas_Sensibles_Denegado	403 en rutas sensibles > 0	R12, R17	firing
API_Enumeracion_Objetos_PosibleBOLA	≥ 2 cestas distintas con 200	R06	firing
RASP_Ataque_Detectado	Líneas «Zen has blocked|detected» > 0	R01, R02	firing
App_Errores_5xx	> 5 respuestas 5xx	R18	inactive

Nota. Elaboración propia con datos del repositorio del laboratorio.

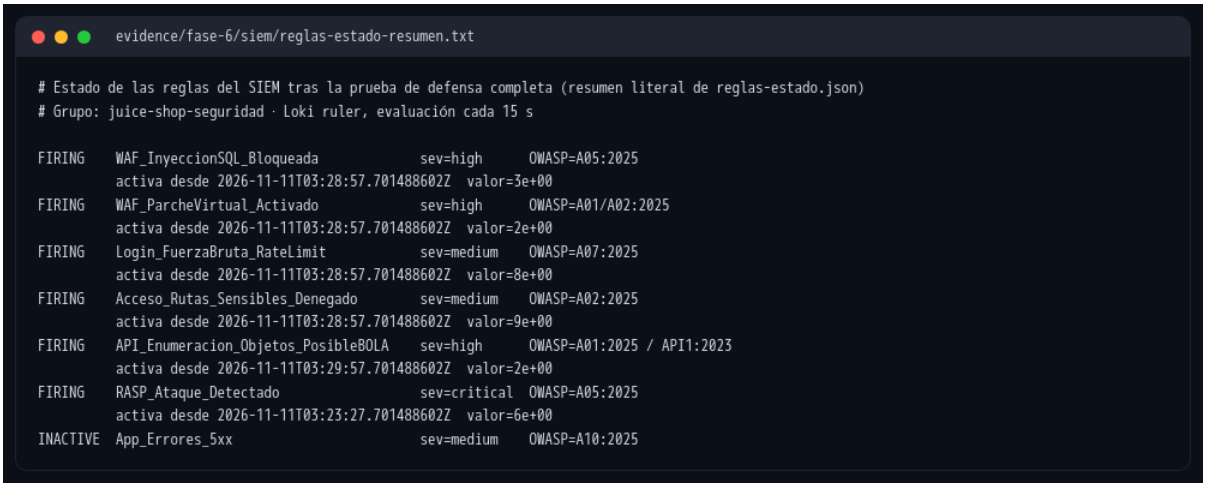


Figura 8. *Estado de las reglas del SIEM tras la prueba de defensa completa: seis reglas en firing con su hora de activación; App_Errores_5xx inactiva porque no hubo ráfagas de errores.*

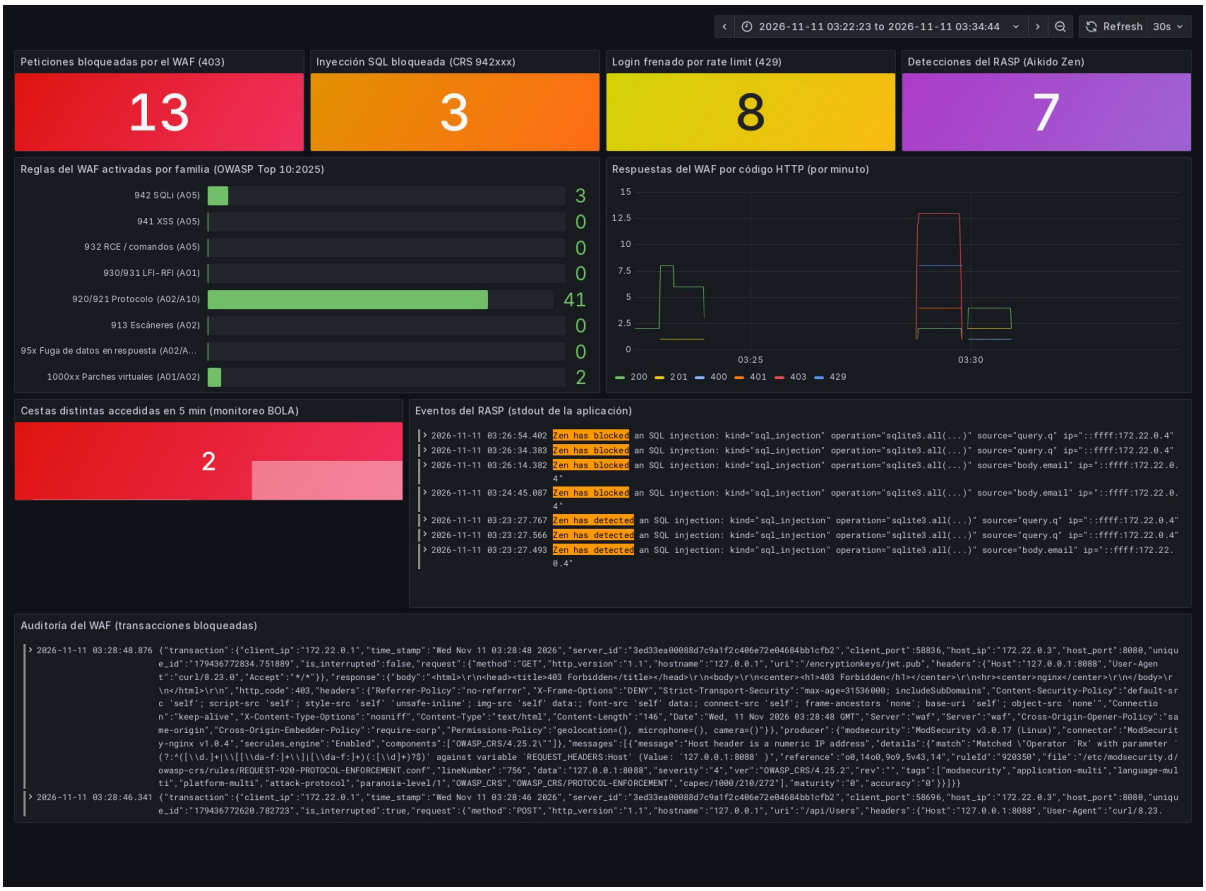


Figura 9. *Panel «SIEM - Juice Shop endurecido» en Grafana durante el periodo de pruebas: bloqueos del WAF, SQLi bloqueadas, rate limit, eventos del RASP, reglas por familia OWASP, respuestas por código HTTP, monitoreo de BOLA y registros crudos.*



Figura 10. *Métricas del periodo de pruebas obtenidas con consultas LogQL a Loki: 13 respuestas 403, 8 respuestas 429, 3 eventos CRS 942, ambos parches virtuales activados, 3 detecciones y 4 bloqueos del RASP, y 3 cestas distintas accedidas.*

Tras la primera captura se corrigió la expresión de la regla del RASP, que también contaba las líneas de advertencia de Node y daba 11 eventos en lugar de 7 (3 detecciones y 4 bloqueos). Ahora solo cuenta las líneas propias del agente (^Zen has

(blocked|detected)). El SIEM es de un solo nodo y Alloy lee la salida de los contenedores mediante el socket de Docker en solo lectura; ambos aspectos se registran como riesgo aceptado para el laboratorio (R24).

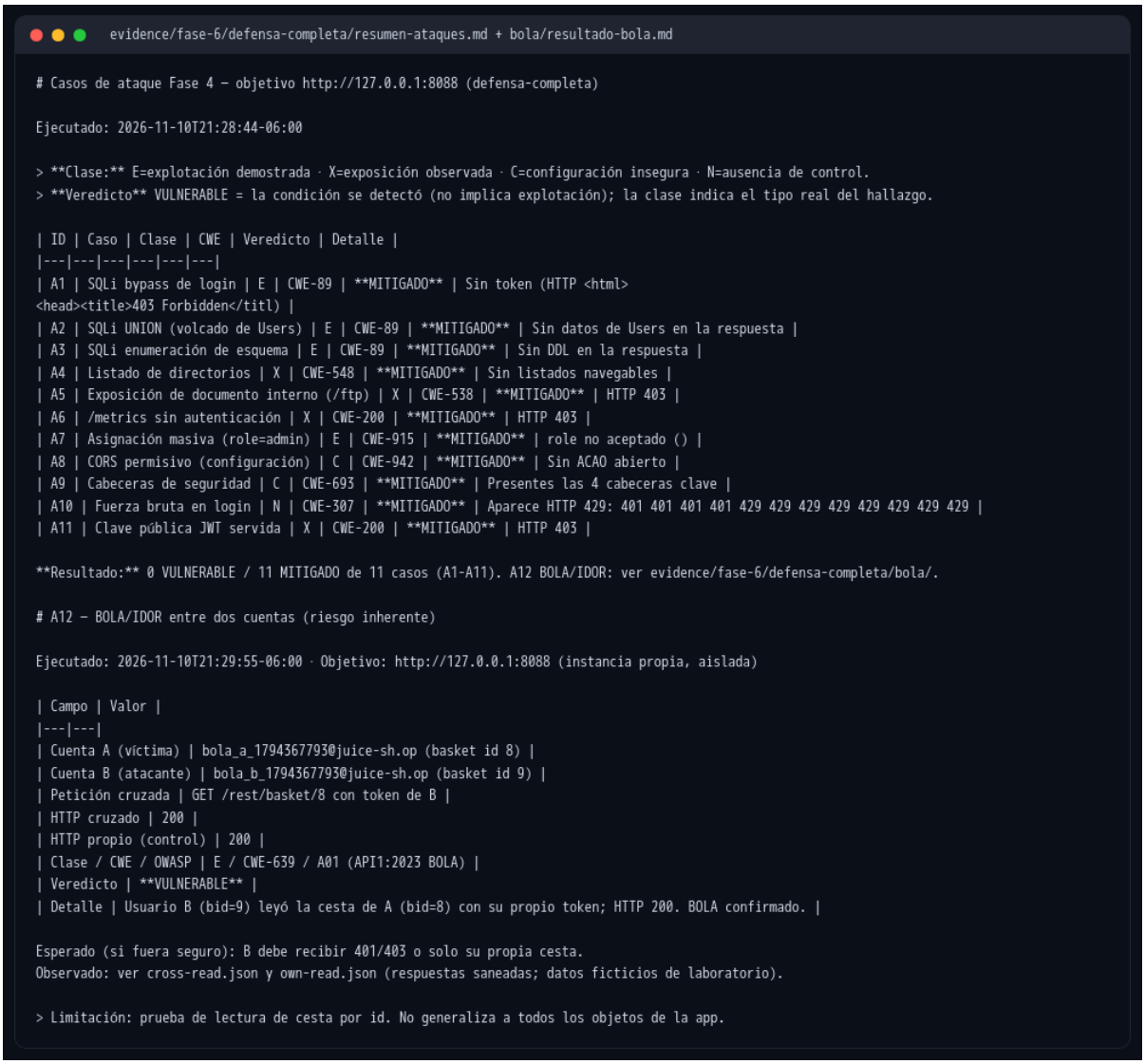
1.6 Verificación integral de los controles

Un control que bloquea tráfico legítimo es un problema operativo. Por eso, antes de medir la protección, se comprobó que la aplicación siguiera funcionando a través del WAF y del RASP: navegación, búsqueda, registro sin el campo role, inicio de sesión, consulta de la cesta propia y lectura de reseñas respondieron correctamente (Figura 11), sin falsos positivos.



Figura 11. *Control de falsos positivos: seis peticiones legítimas a través de WAF y RASP con respuesta 200/201; el token emitido se redacta en la evidencia.*

A continuación se ejecutó el arnés completo contra el punto de entrada real (WAF y aplicación con RASP). Para que el rate limit del inicio de sesión (control de A10) no impidiera obtener los tokens de las dos cuentas de la prueba de BOLA y se confundiera con un control de autorización, se introdujo una pausa configurable antes del caso A12 (A12_DELAY=65).



evidence/fase-6/defensa-completa/resumen-ataques.md + bola/resultado-bola.md

```
# Casos de ataque Fase 4 — objetivo http://127.0.0.1:8088 (defensa-completa)

Ejecutado: 2026-11-10T21:28:44-06:00

> **Clase:** E=explotación demostrada · X=exposición observada · C=configuración insegura · N=ausencia de control.
> **Veredicto** VULNERABLE = la condición se detectó (no implica explotación); la clase indica el tipo real del hallazgo.

| ID | Caso | Clase | CWE | Veredicto | Detalle |
|---|---|---|---|---|---|
| A1 | SQLi bypass de login | E | CWE-89 | **MITIGADO** | Sin token (HTTP <html>
<head><title>403 Forbidden</titl) |
| A2 | SQLi UNION (volcado de Users) | E | CWE-89 | **MITIGADO** | Sin datos de Users en la respuesta |
| A3 | SQLi enumeración de esquema | E | CWE-89 | **MITIGADO** | Sin DDL en la respuesta |
| A4 | Listado de directorios | X | CWE-548 | **MITIGADO** | Sin listados navegables |
| A5 | Exposición de documento interno (/ftp) | X | CWE-538 | **MITIGADO** | HTTP 403 |
| A6 | /metrics sin autenticación | X | CWE-200 | **MITIGADO** | HTTP 403 |
| A7 | Asignación masiva (role=admin) | E | CWE-915 | **MITIGADO** | role no aceptado () |
| A8 | CORS permisivo (configuración) | C | CWE-942 | **MITIGADO** | Sin ACAO abierto |
| A9 | Cabeceras de seguridad | C | CWE-693 | **MITIGADO** | Presentes las 4 cabeceras clave |
| A10 | Fuerza bruta en login | N | CWE-307 | **MITIGADO** | Aparece HTTP 429: 401 401 401 401 429 429 429 429 429 429 429 429 |
| A11 | Clave pública JWT servida | X | CWE-200 | **MITIGADO** | HTTP 403 |

**Resultado:** 0 VULNERABLE / 11 MITIGADO de 11 casos (A1-A11). A12 BOLA/IDOR: ver evidence/fase-6/defensa-completa/bola/.

# A12 — BOLA/IDOR entre dos cuentas (riesgo inherente)

Ejecutado: 2026-11-10T21:29:55-06:00 · Objetivo: http://127.0.0.1:8088 (instancia propia, aislada)

| Campo | Valor |
|---|---|
| Cuenta A (víctima) | bola_a_1794367793@juice-sh.op (basket id 8) |
| Cuenta B (atacante) | bola_b_1794367793@juice-sh.op (basket id 9) |
| Petición cruzada | GET /rest/basket/8 con token de B |
| HTTP cruzado | 200 |
| HTTP propio (control) | 200 |
| Clase / CWE / OWASP | E / CWE-639 / A01 (API1:2023 BOLA) |
| Veredicto | **VULNERABLE** |
| Detalle | Usuario B (bid=9) leyó la cesta de A (bid=8) con su propio token; HTTP 200. BOLA confirmado. |

Esperado (si fuera seguro): B debe recibir 401/403 o solo su propia cesta.
Observado: ver cross-read.json y own-read.json (respuestas saneadas; datos ficticios de laboratorio).

> Limitación: prueba de lectura de cesta por id. No generaliza a todos los objetos de la app.
```

Figura 12. *Defensa completa a través del WAF: A1-A11 mitigados (11/11). El caso A12 (BOLA) sigue vulnerable: la cuenta B leyó la cesta de A con HTTP 200. El encabezado «riesgo inherente» del resultado A12 es un texto fijo del arnés; esta corrida mide el estado residual.*

El resultado confirma el valor y los límites de cada capa. Los once casos A1-A11 quedan mitigados, pero el **BOLA sigue explotable**: un WAF evalúa peticiones, no la propiedad de los objetos, y la petición de la cuenta B es sintácticamente legítima. El SIEM sí lo **detecta** (API_Enumeracion_Objetos_PosibleBOLA) y su eliminación requiere la corrección de código del parche 08, que verifica el propietario de la cesta y responde 403; el parche está validado como diff, pero la aplicación no se recompiló en esta entrega.

2. Tratamiento Formal del Riesgo

El tratamiento sigue el ciclo de ISO/IEC 27005:2022: identificar, analizar, evaluar y tratar. El registro contiene **24 riesgos**: las 20 amenazas STRIDE de la Fase 1 (que incluyen los casos A1-A12 de la Fase 4) y cuatro riesgos adicionales (despliegue en la nube, cumplimiento de protección de datos, el hallazgo del RASP y el riesgo que introduce el propio SIEM). Los datos están en `docs/fase-6/datos/riesgos.json`; el cálculo y las figuras se regeneran con `make risk`.

2.1 Método de valoración reproducible

- **Escala:** probabilidad (P) e impacto (I) de 1 a 5; nivel = P × I: Bajo 1-4, Medio 5-9, Alto 10-16, Crítico 20-25.
- **Riesgo inherente:** P = ⌈media(Reproducibilidad, Explotabilidad, Descubribilidad) / 2⌉ e I = ⌈media(Daño, Afectados) / 2⌉, a partir del DREAD de la Fase 1. Los cuatro riesgos sin DREAD (R21-R24) usan una valoración cualitativa del equipo, marcada como tal.
- **Riesgo residual:** solo cuentan los controles verificados con evidencia. Una eliminación o evitación verificada lleva P a 1; si no la hay, un control preventivo verificado resta 2 a P y dos o más restan 3 (mínimo 1). Una detección verificada resta 1 a I y una contención verificada otro 1 (mínimo 1).
- **Controles diseñados o propuestos** no reducen el residual: se informan como plan de tratamiento.

2.2 Opciones de tratamiento

Tabla 5

Opciones de tratamiento y su equivalencia con ISO/IEC 27005

Decisión	Significado en este proyecto
Mitigar	Reducir probabilidad o impacto con controles (ISO/IEC 27005: modificar).
Eliminar	Suprimir la causa raíz del riesgo (corrección del código o de la configuración).
Evitar	Dejar de realizar la actividad o retirar la funcionalidad que origina el riesgo.
Transferir	Compartir el riesgo con un tercero (proveedor gestionado, póliza o contrato).
Aceptar	Retener el riesgo de forma consciente, documentada y temporal (ISO/IEC 27005: retener).

Nota. Elaboración propia con datos del repositorio del laboratorio.

2.3 Categorización del riesgo por tipo e impacto

Cada riesgo se clasifica por **tipo** (Seguridad, Software, Técnico, Operacional, Cloud y Cumplimiento) y por las categorías de **impacto** que afectaría (Reputacional, Operacional, Financiero y Legal); el impacto principal aparece primero. Distribución por tipo: Seguridad: 16; Software: 2; Técnico: 2; Operacional: 2; Cloud: 1; Cumplimiento: 1. Impactos más frecuentes: Reputacional: 18; Legal: 13; Financiero: 10; Operacional: 10.

Tabla 6

Registro de riesgos: categorización por tipo e impacto

ID	Riesgo	Tipo	Impactos	OWASP 2025	CWE
R01	Inyección SQL en el login (bypass de autenticación)	Seguridad	Reputacional, Legal, Financiero	A05:2025	CWE-89
R02	Inyección SQL UNION en búsqueda (extracción de tablas)	Seguridad	Legal, Reputacional, Financiero	A05:2025	CWE-89
R03	Clave privada JWT embebida en el código (forja de tokens)	Seguridad	Reputacional, Legal, Financiero	A04:2025	CWE-798/321
R04	Bibliotecas JWT obsoletas (algoritmos débiles)	Software	Reputacional, Financiero	A03:2025	CWE-347
R05	Contraseñas con MD5 sin sal	Seguridad	Legal, Reputacional	A04:2025	CWE-916
R06	BOLA/IDOR: lectura de recursos de otro usuario	Seguridad	Legal, Reputacional	A01:2025 (API1:2023)	CWE-639
R07	Asignación masiva de role=admin en el registro	Seguridad	Reputacional, Financiero	A01:2025	CWE-915
R08	Inyección NoSQL en reseñas (MarsDB)	Seguridad	Reputacional, Operacional	A05:2025	CWE-943
R09	Ejecución de código via eval()/vm	Seguridad	Operacional, Reputacional, Financiero	A05:2025	CWE-95
R10	XXE en la carga de XML	Seguridad	Legal, Operacional	A02:2025	CWE-611
R11	SSRF en la imagen de perfil por URL	Seguridad	Operacional, Legal	A01:2025	CWE-918
R12	Listado de directorios y archivos internos (/ftp, /encryptionkeys)	Seguridad	Reputacional, Legal	A02:2025	CWE-548/538
R13	XSS (CSP debil, sin codificación de salida)	Seguridad	Reputacional, Legal	A05:2025	CWE-79
R14	CORS permisivo (ACAO *)	Seguridad	Reputacional	A02:2025	CWE-942
R15	Redirección abierta (lista blanca evadible)	Seguridad	Reputacional	A01:2025	CWE-601
R16	Fuerza bruta en el login (sin limitación de intentos)	Seguridad	Reputacional, Operacional	A07:2025	CWE-307
R17	/metrics expuesto sin autenticación	Seguridad	Reputacional	A02:2025	CWE-200
R18	Denegación de servicio por vm/ZIP (agotamiento de recursos)	Técnico	Operacional, Financiero	A10:2025	CWE-400
R19	Registro sin centralización ni alertas	Operacional	Operacional, Legal	A09:2025	CWE-778
R20	Dependencias con CVE criticas (cadena de suministro)	Software	Financiero, Reputacional, Legal	A03:2025	CWE-1395
R21	Configuración insegura al desplegar la arquitectura cloud (AWS)	Cloud	Financiero, Operacional, Legal	A02:2025	CWE-16
R22	RASP en modo bloqueo provoca la caída del proceso (auto-DoS)	Técnico	Operacional, Reputacional	A10:2025	CWE-248/755
R23	Exposición de datos personales (incumplimiento de protección de datos)	Cumplimiento	Legal, Reputacional, Financiero	A01/ A05:2025	CWE-200

ID	Riesgo	Tipo	Impactos	OWASP 2025	CWE
R24	SIEM de un solo nodo (sin alta disponibilidad; agente con acceso al socket de Docker)	Operacional	Operacional	A09:2025	CWE-250

Nota. Elaboración propia con datos del repositorio del laboratorio.

2.4 Matriz de decisiones por riesgo

Las cinco opciones se aplican. Como decisión principal: Mitigar 9, Eliminar 9, Evitar 3, Aceptar 3, Transferir 0; Transferir actúa como decisión complementaria en R03 (gestor de secretos o KMS del proveedor cloud), R21 (servicios gestionados y responsabilidad compartida) y R23 (póliza de ciberriesgo o cláusulas contractuales). Las tres aceptaciones (R04, R20 y R24) son temporales y se limitan al laboratorio: actualizar las bibliotecas rompe los retos de Juice Shop y el SIEM de un solo nodo es suficiente para la prueba; en producción la decisión sería Eliminar.

Tabla 7

Matriz de decisiones: riesgo inherente, decisión y riesgo residual

ID	Inherente P×I	Decisión	Complementaria	Residual P×I	Fuente P/I
R01	5×5 = 25 Crítico	Mitigar	Eliminar	2×4 = 8 Medio	DREAD F1
R02	5×5 = 25 Crítico	Mitigar	Eliminar	2×4 = 8 Medio	DREAD F1
R03	4×5 = 20 Crítico	Eliminar	Transferir	4×5 = 20 Crítico	DREAD F1
R04	3×5 = 15 Alto	Aceptar	Eliminar	3×4 = 12 Alto	DREAD F1
R05	4×5 = 20 Crítico	Eliminar	Mitigar	2×4 = 8 Medio	DREAD F1
R06	5×4 = 20 Crítico	Eliminar	Mitigar	5×3 = 15 Alto	DREAD F1
R07	4×4 = 16 Alto	Mitigar	Eliminar	2×3 = 6 Medio	DREAD F1
R08	4×4 = 16 Alto	Eliminar	—	4×4 = 16 Alto	DREAD F1
R09	3×5 = 15 Alto	Eliminar	Mitigar	3×4 = 12 Alto	DREAD F1
R10	3×5 = 15 Alto	Eliminar	—	3×5 = 15 Alto	DREAD F1
R11	4×3 = 12 Alto	Mitigar	Eliminar	4×3 = 12 Alto	DREAD F1
R12	5×4 = 20 Crítico	Evitar	Mitigar	3×3 = 9 Medio	DREAD F1
R13	4×4 = 16 Alto	Mitigar	Eliminar	2×4 = 8 Medio	DREAD F1
R14	4×3 = 12 Alto	Mitigar	Eliminar	2×3 = 6 Medio	DREAD F1
R15	4×3 = 12 Alto	Eliminar	—	4×3 = 12 Alto	DREAD F1
R16	5×3 = 15 Alto	Mitigar	—	3×2 = 6 Medio	DREAD F1
R17	5×2 = 10 Alto	Evitar	Mitigar	2×1 = 2 Bajo	DREAD F1
R18	3×4 = 12 Alto	Mitigar	—	3×3 = 9 Medio	DREAD F1
R19	3×4 = 12 Alto	Eliminar	—	1×3 = 3 Bajo	DREAD F1
R20	4×5 = 20 Crítico	Aceptar	Eliminar	4×4 = 16 Alto	DREAD F1
R21	3×4 = 12 Alto	Evitar	Transferir	1×4 = 4 Bajo	Cualitativa
R22	5×3 = 15 Alto	Eliminar	—	1×3 = 3 Bajo	Cualitativa
R23	5×5 = 25 Crítico	Mitigar	Transferir	3×4 = 12 Alto	Cualitativa
R24	2×3 = 6 Medio	Aceptar	—	2×2 = 4 Bajo	Cualitativa

Nota. Elaboración propia con datos del repositorio del laboratorio.

2.5 Matriz de calor: probabilidad frente a impacto

Las figuras siguientes ubican cada riesgo según su probabilidad y su impacto antes (inherente) y después (residual) de aplicar los controles verificados. El número de la esquina de cada celda es el producto P × I.

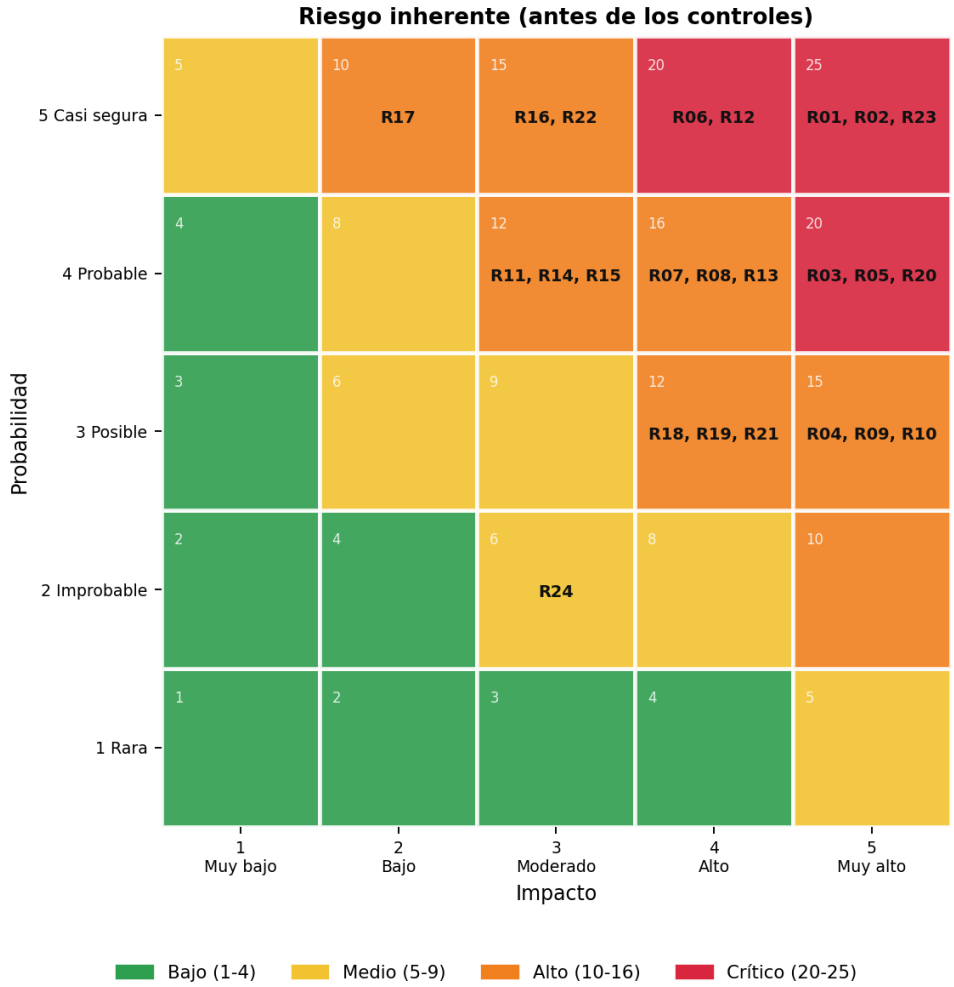


Figura 13. *Matriz de calor del riesgo inherente: 8 riesgos críticos y 15 altos, concentrados en probabilidades 4-5.*

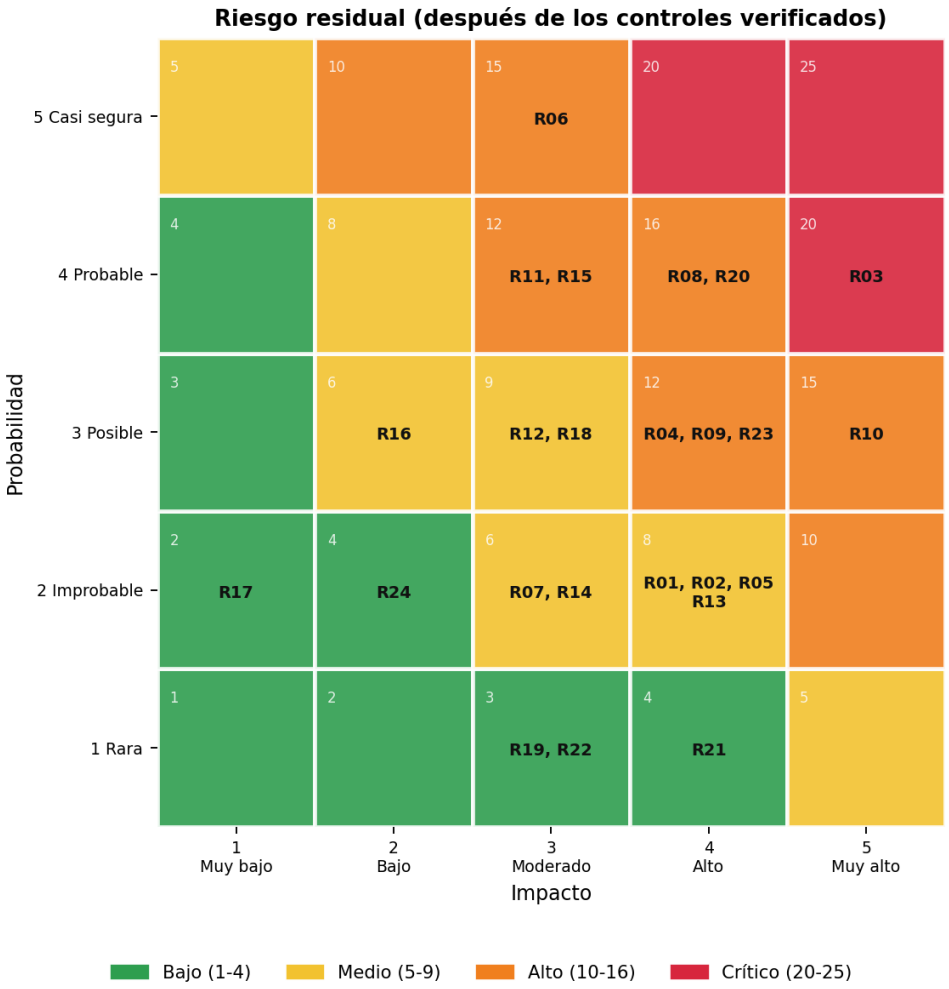


Figura 14. *Matriz de calor del riesgo residual tras los controles verificados: 1 crítico (R03), 9 altos, 9 medios y 5 bajos.*

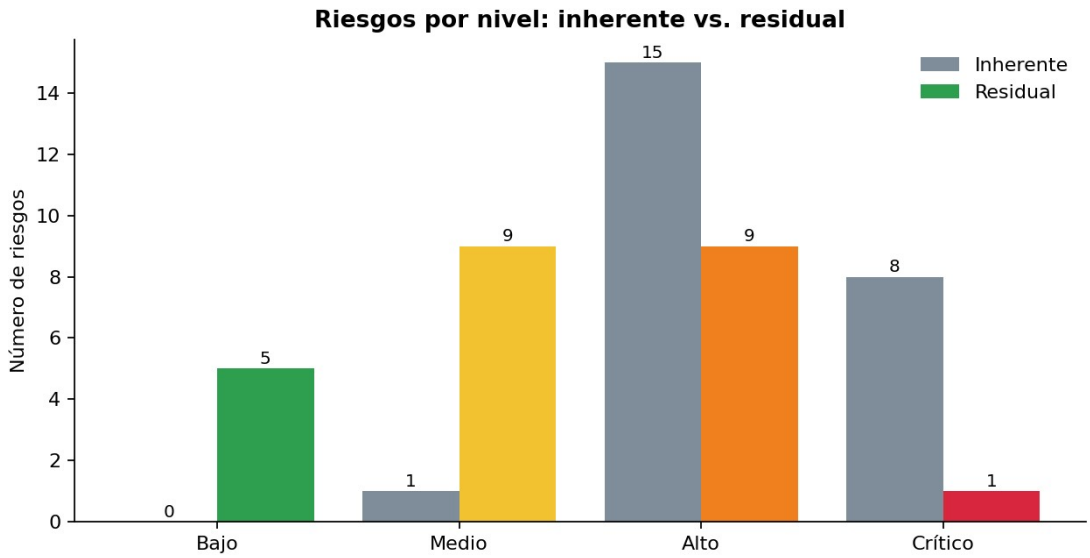


Figura 15. *Distribución de los 24 riesgos por nivel: inherente frente a residual.*

Tabla 8

Riesgos por nivel antes y después de los controles

Nivel	Inherente	Residual
Bajo	0	5
Medio	1	9
Alto	15	9
Crítico	8	1

Nota. Elaboración propia con datos del repositorio del laboratorio.

2.6 Lectura del riesgo residual

- Quedan **10 riesgos Alto o Crítico** (R03, R04, R06, R08, R09, R10, R11, R15, R20, R23). Su tratamiento definitivo —parches de código, actualización de dependencias, parser XML seguro, lista blanca contra SSRF— está diseñado o propuesto, pero no desplegado, por lo que el método no les concede reducción.
- **R03** (clave privada JWT embebida) sigue **Crítico**: ningún control desplegado detecta un token forjado con esa clave. La prioridad es desplegar el parche 04 con un gestor de secretos.
- **R06** (BOLA) baja solo en impacto: el WAF no lo bloquea (verificado) y el SIEM lo detecta. El parche 08 lo eliminaría.
- Los mayores descensos corresponden a riesgos con controles preventivos verificados en varias capas: R01 y R02 (SQLi: WAF + RASP + alerta), R12 y R17

(rutas sensibles), R16 (fuerza bruta) y R19 (registro sin alertas, eliminado con el SIEM).

- R22, el riesgo introducido por el propio RASP, se identificó, se trató y se verificó dentro de la fase; muestra que cada control nuevo también debe evaluarse como fuente de riesgo.

Limitaciones y trabajo futuro

- Los parches de código 01-08 se validaron como diff, pero la aplicación no se recompiló; desplegarlos permitiría medir el residual sin depender del WAF y reduciría R03, R05, R06, R07, R09 y R14.
- RASP: integrar su protección IDOR y gestionar el error de bloqueo en la capa de datos para responder 403 en lugar de dejar la petición sin respuesta.
- SIEM de un solo nodo, sin alta disponibilidad ni notificaciones externas; en producción se usaría un clúster gestionado, el driver de registros de Docker en lugar del socket y la notificación por Alertmanager, correo o chat.
- La infraestructura cloud de la Fase 2 no se desplegó para evitar costos: el diseño en Terraform está validado estáticamente con Checkov (144 aprobadas, 0 fallidas).
- Las reglas del CRS distintas de la 942 (XSS, RCE, LFI y fugas en respuestas) están cargadas, pero esta fase no las ejercitó con pruebas específicas; su cobertura se documenta como configurada, no verificada.

Conclusiones

La Fase 6 integró y verificó una estrategia de defensa en profundidad sobre la aplicación endurecida. El WAF mitigó los once casos A1-A11 sin bloquear el tráfico legítimo, el RASP detectó y bloqueó las inyecciones SQL dentro de la aplicación incluso con el perímetro evadido, y el SIEM centralizó los registros y activó seis de sus siete reglas durante las pruebas, incluida la detección del BOLA que ningún control perimetral bloquea.

La operación también reveló fallos que solo aparecen al poner los controles en funcionamiento: el RASP en modo bloqueo provocaba la caída del proceso, el healthcheck del WAF lo marcaba como no saludable y una regla del SIEM sobrecontaba eventos. Los tres se corrigieron y se verificaron con evidencia. Esta experiencia confirma que un control desplegado no equivale a un control efectivo hasta que se prueba.

El tratamiento formal del riesgo, calculado de forma reproducible a partir del DREAD de la Fase 1, redujo los riesgos críticos de 8 a 1 y los altos de 15 a 9. El residual no es nulo: el riesgo crítico restante (R03) y varios altos dependen de correcciones de código diseñadas pero no desplegadas. Presentarlos así, sin conceder reducciones a controles no verificados, es la base honesta para priorizar el trabajo siguiente.

Referencias

Aikido Security. (2026). Zen for Node.js (Versión 1.8.46) [Software]. https://github.com/AikidoSec/firewall-node

Grafana Labs. (s. f.-a). Grafana Alloy documentation. https://grafana.com/docs/alloy/latest/

Grafana Labs. (s. f.-b). Grafana Loki documentation. https://grafana.com/docs/loki/latest/

International Organization for Standardization. (2022). Information security, cybersecurity and privacy protection — Guidance on managing information security risks (ISO/IEC 27005:2022).

Kent, K., y Souppaya, M. (2006). Guide to computer security log management (NIST Special Publication 800-92). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-92

Kimminich, B. (2026). OWASP Juice Shop (Versión 20.3.0) [Software]. OWASP Foundation. https://github.com/juice-shop/juice-shop

MITRE Corporation. (s. f.). CWE: Common Weakness Enumeration. https://cwe.mitre.org/

OWASP CRS Project. (s. f.). OWASP CRS (Versión 4.25.2) [Software]. https://coreruleset.org/

OWASP Foundation. (2023). OWASP API Security Top 10 – 2023. https://owasp.org/API-Security/editions/2023/en/0x11-t10/

OWASP Foundation. (2025). OWASP Top 10:2025. https://owasp.org/Top10/2025/

OWASP Foundation. (s. f.). ModSecurity (Versión 3.0.17) [Software]. https://github.com/owasp-modsecurity/ModSecurity

Anexos

Anexo A. Integridad de la evidencia de la Fase 6 (SHA-256)

Extracto de evidence/MANIFEST.sha256 con los archivos de la Fase 6. Se verifica con sha256sum -c MANIFEST.sha256 desde evidence/. El manifiesto solo incluye archivos versionados; las corridas locales ignoradas por git no figuran.

```
3169e53e998197ae01930fa828f7f6e678b66f47adc3e46d9ddc6e4041599aa2  fase-6/defensa-completa/a1-sqli-login.json
e38857a6b47114d67e030dfe40fc0df6a5f58d49001d2229d9091bc8615776fe  fase-6/defensa-completa/a10-bruteforce-login.txt
3169e53e998197ae01930fa828f7f6e678b66f47adc3e46d9ddc6e4041599aa2  fase-6/defensa-completa/a11-jwt-key.txt
3169e53e998197ae01930fa828f7f6e678b66f47adc3e46d9ddc6e4041599aa2  fase-6/defensa-completa/a2-sqli-union-search.json
3169e53e998197ae01930fa828f7f6e678b66f47adc3e46d9ddc6e4041599aa2  fase-6/defensa-completa/a3-sqli-schema.json
c5bcadc3d788fd4646ba87bb4f6c2057ead6266828cae7a05e8611f4d84a2401  fase-6/defensa-completa/a4-directory-listing.txt
3169e53e998197ae01930fa828f7f6e678b66f47adc3e46d9ddc6e4041599aa2  fase-6/defensa-completa/a5-acquisitions.md
3169e53e998197ae01930fa828f7f6e678b66f47adc3e46d9ddc6e4041599aa2  fase-6/defensa-completa/a6-metrics.txt
3169e53e998197ae01930fa828f7f6e678b66f47adc3e46d9ddc6e4041599aa2  fase-6/defensa-completa/a7-mass-assignment.json
0bf376bdd106147578a68dca9d584e6a82e9bfceef46593f576ec9a275c0ca62  fase-6/defensa-completa/a8-cors-headers.txt
ce5c80171b4a5618e988851d5997f36785d148cf19eb2769cd0c789a29b2d35a  fase-6/defensa-completa/a9-security-headers.txt
ae4ae70c0987abbec397a25fc435f35f88c9f9a817c4c3e71c238a698b4fc47c  fase-6/defensa-completa/bola/cross-read.json
2d45e62c8d646458a9025a333af5655fbf71ad9865bab9e77a2794386bbf5634  fase-6/defensa-completa/bola/own-read.json
c0225e8552fa52d8caa4cd53131c5a50c07df3b4f3afddaf6e9c770e14be1810  fase-6/defensa-completa/bola/resultado-bola.md
0a6731f547e125c6604cc833ba2f4f22471986161b19298f15ed6a4f8ab42e34  fase-6/defensa-completa/resumen-ataques.md
970a8db47dba2b0c707303afba4390d2c5aebbbaa600b03f69cd25b1d848462a  fase-6/funcional/trafico-legitimo.txt
630b1744e8947bee12bf25b532df23d69ff8a0215b0afd2fbbf8bd751fb43535  fase-6/rasp/01-deteccion-sin-bloqueo/LEAME-redaccion.md
9850c363016b0bf1a3f0501f761df204d800e46a4aebc2f6f57485482c06997a  fase-6/rasp/01-deteccion-sin-bloqueo/a1-sqli-login.json
e414041ef042e8cd1369303fd7f521f2a97bd1134adbe080036682d52376ea65  fase-6/rasp/01-deteccion-sin-bloqueo/a10-bruteforce-login.txt
89fdb7cbbc50749d7a72fbf3452e5ba537d01e176b8e686b3f8536627c11f338  fase-6/rasp/01-deteccion-sin-bloqueo/a11-jwt-key.txt
f199526fada1a39d93c9d353324f2e85d78b71ce3974cf1fed8e589bf4343e9c  fase-6/rasp/01-deteccion-sin-bloqueo/a2-sqli-union-search.json
9098cfa7a99ad97cc30c8a23e40dd6cef99907b52e07cec3b7b3de9dbd77c3db  fase-6/rasp/01-deteccion-sin-bloqueo/a3-sqli-schema.json
be86b35a56b7a04a1d9b6725cda48a18247a5be2d89c99fdb4df9fc1f236382e  fase-6/rasp/01-deteccion-sin-bloqueo/a4-directory-listing.txt
48321ee73b6b6de85cd390e3f395ba794639a268d094201f45c3f973cac441fd  fase-6/rasp/01-deteccion-sin-bloqueo/a5-acquisitions.md
bf1fdcaab7784b1961f2f7b4c110f61c8dd201188a892692671c04e20b4fc174  fase-6/rasp/01-deteccion-sin-bloqueo/a6-metrics.txt
3d3a221a79343e9a925ba0e94847625f17408e57e3e64bd9db31968455c69fcd  fase-6/rasp/01-deteccion-sin-bloqueo/a7-mass-assignment.json
f5716a40a631f5882f91e490ac9a31ffcc5c4a9cd6c3690bfa524e1a7b1a6fc6  fase-6/rasp/01-deteccion-sin-bloqueo/a8-cors-headers.txt
ea5b4efe4dee6201eb6f9f51d777c1ca700758ae0b49f9f17c3779f43d07fe58  fase-6/rasp/01-deteccion-sin-bloqueo/a9-security-headers.txt
ace1cea8ef9bc396156c8c846bb165182aeaaeebab03c76ff2c7f4976ab81155  fase-6/rasp/01-deteccion-sin-bloqueo/bola/cross-read.json
b78208233c619a3f9ece4535c71d99afbf26ba33a8cd45139849970dc951182f  fase-6/rasp/01-deteccion-sin-bloqueo/bola/own-read.json
86ce308979e34706555ed5bb20a322fe7e42ca69842f7e7e3f2428f5258b0de9  fase-6/rasp/01-deteccion-sin-bloqueo/bola/resultado-bola.md
9b5a45747883d65c5a881503a276ebd3f958ab42aba4aaae139e4eb1f4b9bb7e  fase-6/rasp/01-deteccion-sin-bloqueo/rasp-detecciones.log
72a0dc2cd998fe6143e7fdca2906976a1b21bbc227445a6c430bfffc1340f630  fase-6/rasp/01-deteccion-sin-bloqueo/resumen-ataques.md
8fb6b1a12c84f368ad7db5350935ce3f439cb64ac5c1f8bef38513f1225973f8  fase-6/rasp/02-bloqueo-caida-del-proceso/LEAME-corrida-
invalida.md
01ba4719c80b6fe911b091a7c05124b64eeece964e09c058ef8f9805daca546b  fase-6/rasp/02-bloqueo-caida-del-proceso/a1-sqli-login.json
e4fb5b1c0a82f9b481d063c1c36a7bf8eaa52c90f84262c43b2cfcc7460b3c49  fase-6/rasp/02-bloqueo-caida-del-proceso/a10-bruteforce-login.txt
01ba4719c80b6fe911b091a7c05124b64eeece964e09c058ef8f9805daca546b  fase-6/rasp/02-bloqueo-caida-del-proceso/a2-sqli-union-
search.json
01ba4719c80b6fe911b091a7c05124b64eeece964e09c058ef8f9805daca546b  fase-6/rasp/02-bloqueo-caida-del-proceso/a3-sqli-schema.json
b316166563fa1b01feebc3d6b532d4fa66df9d31310b65e29a78906b21f5bd98  fase-6/rasp/02-bloqueo-caida-del-proceso/a4-directory-listing.txt
01ba4719c80b6fe911b091a7c05124b64eeece964e09c058ef8f9805daca546b  fase-6/rasp/02-bloqueo-caida-del-proceso/a7-mass-
assignment.json
01ba4719c80b6fe911b091a7c05124b64eeece964e09c058ef8f9805daca546b  fase-6/rasp/02-bloqueo-caida-del-proceso/a8-cors-headers.txt
01ba4719c80b6fe911b091a7c05124b64eeece964e09c058ef8f9805daca546b  fase-6/rasp/02-bloqueo-caida-del-proceso/a9-security-headers.txt
b1f15e6d23ce0415a735f5a38a29bd33fe2464396edcbd6ace9251f6ec67ab17  fase-6/rasp/02-bloqueo-caida-del-proceso/bola/resultado-bola.md
4a57b13fba3e2f67f6cc074192c21f50279a77889ce44e8e0e915282c1d0eea6  fase-6/rasp/02-bloqueo-caida-del-proceso/rasp-caida.log
a35d585bf06d78d6b6c1e6e55fefccdc29c6771762c4ba64655c7b342f43e471  fase-6/rasp/02-bloqueo-caida-del-proceso/resumen-ataques.md
01ba4719c80b6fe911b091a7c05124b64eeece964e09c058ef8f9805daca546b  fase-6/rasp/03-bloqueo-sin-caida/a1-sqli-login.json
e414041ef042e8cd1369303fd7f521f2a97bd1134adbe080036682d52376ea65  fase-6/rasp/03-bloqueo-sin-caida/a10-bruteforce-login.txt
89fdb7cbbc50749d7a72fbf3452e5ba537d01e176b8e686b3f8536627c11f338  fase-6/rasp/03-bloqueo-sin-caida/a11-jwt-key.txt
01ba4719c80b6fe911b091a7c05124b64eeece964e09c058ef8f9805daca546b  fase-6/rasp/03-bloqueo-sin-caida/a2-sqli-union-search.json
01ba4719c80b6fe911b091a7c05124b64eeece964e09c058ef8f9805daca546b  fase-6/rasp/03-bloqueo-sin-caida/a3-sqli-schema.json
be86b35a56b7a04a1d9b6725cda48a18247a5be2d89c99fdb4df9fc1f236382e  fase-6/rasp/03-bloqueo-sin-caida/a4-directory-listing.txt
48321ee73b6b6de85cd390e3f395ba794639a268d094201f45c3f973cac441fd  fase-6/rasp/03-bloqueo-sin-caida/a5-acquisitions.md
```

d2fc092c0b6f4040d044f4d86491d565fbba4f456080dfd21c055f83e63f1073 fase-6/rasp/03-bloqueo-sin-caida/a6-metrics.txt
449b63a3d459a48380e272a666e81a6a209185b398ef01928579a3e3843ded12 fase-6/rasp/03-bloqueo-sin-caida/a7-mass-assignment.json
92a50789cc1c0cadac2705eca2f67c24c9d123169413bef109d35a8878895e31 fase-6/rasp/03-bloqueo-sin-caida/a8-cors-headers.txt
05eea9e11d58b36a970011cabeb9a01a72466cf35085527dc3bdfcc758740d9b fase-6/rasp/03-bloqueo-sin-caida/a9-security-headers.txt
e095959c7ce74385f262b1777ac5755eebde5b8f4197da3ac71315e4e73c5b38 fase-6/rasp/03-bloqueo-sin-caida/bola/cross-read.json
43b65b8f836e080ada6b59927a3e2982d017c39fd8a9358492a9cacfeaea2745 fase-6/rasp/03-bloqueo-sin-caida/bola/own-read.json
9237b1d5d5016f15c5cb0ace4489f076b0a971fcf868032dc642b80ac8bf37b0 fase-6/rasp/03-bloqueo-sin-caida/bola/resultado-bola.md
39fa0192847aa1ecf1b2377f04f576b923327e0dba5875854bd810c4286e20f9 fase-6/rasp/03-bloqueo-sin-caida/rasp-bloqueos.log
7ba83ad55c5599691a00db5880f1ebeac77a8dae528c7a1c96e078139191af9a fase-6/rasp/03-bloqueo-sin-caida/resumen-ataques.md
66f0e64af2c6b3db7b8c66701443d3de5f2b3ffea16c58ff63180e22aabf70f5 fase-6/rasp/arranque-agente.log
c8238fe995170f1a4e949509e290c0bf95aa0ddbc6ffc92edd0c314da9b427ee fase-6/siem/alertas-tras-defensa-completa.json
fdb175fb4d0257911348a33b68e72ce2e4ad0ef6bb9f01de1a7cd24ad049abe6 fase-6/siem/alertas-tras-prueba-rasp.json
e3d23c8f35959d3fc47e754994faafbb1d66c0fd1675c4c3bf38e6fdd229f399 fase-6/siem/capturas/grafana-dashboard-siem.png
de05b84809f43dac5fde94bc3e89fdaa35f04bb0410417f22118c982fe7b4af6 fase-6/siem/consultas-logql-resumen.txt
8d8275b4b5a9a8dc244904f05224b57743fcd88518bf0a295e2b4acd27af8f72 fase-6/siem/consultas-logql.jsonl
2d8a3af006826ea80acc315ff0c7dcd681c0fbbf7878af85993eb802ba1890c4 fase-6/siem/reglas-estado-resumen.txt
bf84e1444fb622332fda6af453e99e1d71676f09eeeffd06d992f6046e567a57 fase-6/siem/reglas-estado.json
3e76dee98e16aea322a9e6a8ec75503fc7f0ddc8047cbac66d48b0a5a60603e9 fase-6/siem/stack-docker-ps.txt
598b4da7f56ecdccc128bec594851584428a1d6d592b186a451765b305993b83 fase-6/waf-logs/fase6-2026-11-10/modsec-audit.redactado.log
7c6c5e9986225ef255353236363f4372d4e393491874e38ac90209303f8bd460 fase-6/waf-logs/fase6-2026-11-10/waf-access.log
d62780de813bb1a324362c678cbd0916bf6c0e748a74ad5798de84aaacef2c81 fase-6/waf-logs/modsec-audit.log
878693409d38b91f357ea99a26348ec29f0a7361cd04e92738e14b4d7e78345c fase-6/waf-logs/resumen-bloqueos.md
876b9f8ddf60327ed97999d01d591f1f66227ffbd3ec6ea8a9604164b0a87f74 fase-6/waf/crs-inventario.txt

Anexo B. Bitácora de comandos de la Fase 6

Entradas de evidence/bitacora.md del 2026-11-10 (fecha, fase, comando, herramienta y resultado). La entrada «CORRECCIÓN» documenta la corrida inválida del RASP.

2026-11-10T21:24:05-06:00 · Fase 4 · security/attacks/run.sh (http://juice-hardened:3000, rasp-deteccion) · curl + código del laboratorio · 11 VULNERABLE / 0 MITIGADO de 11. /work/evidence/fase-6/rasp/01-deteccion-sin-bloqueo/resumen-ataques.md

2026-11-10T21:24:46-06:00 · Fase 4 · security/attacks/run.sh (http://juice-hardened:3000, rasp-bloqueo) · curl + código del laboratorio · 2 VULNERABLE / 9 MITIGADO de 11. /work/evidence/fase-6/rasp/02-bloqueo/resumen-ataques.md

2026-11-10T21:27:51-06:00 · Fase 4 · security/attacks/run.sh (http://juice-hardened:3000, rasp-bloqueo-sin-caida) · curl + código del laboratorio · 8 VULNERABLE / 3 MITIGADO de 11. /work/evidence/fase-6/rasp/03-bloqueo-sin-caida/resumen-ataques.md

2026-11-10T21:29:55-06:00 · Fase 4 · security/attacks/run.sh (http://127.0.0.1:8088, defensa-completa) · curl + código del laboratorio · 0 VULNERABLE / 11 MITIGADO de 11. /c/Users/CHINO/Desktop/Proyecto Seg Aplicacion/evidence/fase-6/defensa-completa/resumen-ataques.md

2026-11-10T21:33:34-06:00 · Fase 6 · docker compose -f docker-compose.yml -f docker-compose.ops.yml up -d --build (WAF_PORT=8088) · WAF CRS 4.25.2/ModSecurity 3.0.17; Aikido Zen 1.8.46; Loki 3.5.5, Alloy v1.10.2, Grafana 12.1.1 · Stack de operaciones arriba solo en 127.0.0.1 (WAF 8088 porque 8080 lo ocupa un proceso javaw del equipo; Grafana 3001; Loki 3100). RASP sin token: sin reporte externo.

2026-11-10T21:33:34-06:00 · Fase 6 · trafico legitimo via WAF+RASP (control de falsos positivos) · curl · 6/6 peticiones legitimas 200/201 (busqueda, registro sin role, login, cesta propia). evidence/fase-6/funcional/trafico-legitimo.txt

2026-11-10T21:33:34-06:00 · Fase 6 · run.sh directo a juice-hardened:3000, RASP AIKIDO_BLOCK=false (sin WAF) · Aikido Zen 1.8.46 · Modo monitoreo: 3 SQLi detectadas (body.email, query.q x2) en sqlite3.all; ataques no bloqueados (esperado). evidence/fase-6/rasp/01-deteccion-sin-bloqueo/

2026-11-10T21:33:35-06:00 · Fase 6 · CORRECCION de la entrada rasp-bloqueo (21:24:46): corrida INVALIDA · Aikido Zen 1.8.46 · El primer bloqueo hizo terminar el proceso Node (rechazo no manejado, RestartCount=1); los MITIGADO fueron HTTP 000. Carpeta renombrada a evidence/fase-6/rasp/02-bloqueo-caida-del-proceso/ (ver LEAME)

2026-11-10T21:33:35-06:00 · Fase 6 · run.sh directo, RASP AIKIDO_BLOCK=true + --unhandled-rejections=warn (sin WAF) · Aikido Zen 1.8.46, Node 24.21.0 · A1-A3 bloqueadas por el RASP sin caida del proceso (RestartCount 0); resto vulnerable sin WAF (fuera del alcance del RASP). evidence/fase-6/rasp/03-bloqueo-sin-caida/

2026-11-10T21:33:35-06:00 · Fase 6 · run.sh via WAF 127.0.0.1:8088 con RASP (defensa completa, A12_DELAY=65) · WAF + RASP · A1-A11 MITIGADO (11/11); A12 BOLA sigue VULNERABLE a traves del WAF (B leyo cesta de A, HTTP 200): el WAF no controla propiedad de objetos. evidence/fase-6/defensa-completa/

2026-11-10T21:33:35-06:00 · Fase 6 · Loki ruler /prometheus/api/v1/rules y LogQL · Loki 3.5.5 · 6/7 reglas firing (SQLi WAF, parche virtual, fuerza bruta 429, rutas sensibles, enumeracion BOLA, RASP); App_Errores_5xx inactiva. evidence/fase-6/siem/

2026-11-10T21:44:01-06:00 · Fase 6 · healthcheck del WAF: imagen probaba https://localhost:8443/healthz (no servido) -> override HTTP 8080/healthz · Docker 29.9.2, owasp/modsecurity-crs 4.25.2 · juice-waf pasa de unhealthy a healthy; trafico sin cambios. deploy/hardened/docker-compose.yml

2026-11-10T21:52:56-06:00 · Fase 6 · node build.js (2 pasadas: indice con paginas reales leidas del PDF) + soffice --convert-to pdf · docx 9.5.1 (Node 24, Docker), LibreOffice, poppler pdftotext · Entregable Word+PDF de la Fase 6: 32 paginas, 15 figuras, 8 tablas, anexos con MANIFEST y bitacora. docs/fase-6/entregable/

Anexo C. Reglas de correlación del SIEM (LogQL)

Contenido de deploy/hardened/siem/rules/fake/alertas.yaml, evaluado por el ruler de Loki.

```
# Reglas de correlación y alerta del SIEM (Loki ruler, LogQL). Fase 6.
# Cada regla se asocia a un riesgo del registro (docs/fase-6/tratamiento-riesgo.md) y a OWASP Top 10:2025.
# Ventanas cortas (5 min) para el laboratorio; en producción se ajustarían umbrales y supresión.
groups:
 - name: juice-shop-seguridad
   interval: 15s
   rules:
    - alert: WAF_InyeccionSQL_Bloqueada
      expr: sum(count_over_time({job="waf_audit"} |= "\"ruleId\":\"942" [5m])) > 0
      labels: {severity: high, owasp: "A05:2025", riesgo: "R01,R02", fuente: waf}
      annotations:
        summary: "El WAF bloqueó intentos de inyección SQL (familia CRS 942xxx)"

    - alert: WAF_ParcheVirtual_Activado
      expr: sum(count_over_time({job="waf_audit"} |~ "\"ruleId\":\"10000[0-9]\"" [5m])) > 0
      labels: {severity: high, owasp: "A01/A02:2025", riesgo: "R07,R17", fuente: waf}
      annotations:
        summary: "Se activó un parche virtual propio (100001 asignación masiva / 100002 /metrics)"

    - alert: Login_FuerzaBruta_RateLimit
      expr: sum(count_over_time({job="waf_access", status="429"} [5m])) >= 3
      labels: {severity: medium, owasp: "A07:2025", riesgo: "R16", fuente: waf}
      annotations:
        summary: "Ráfaga de intentos de login frenada por limitación de tasa (HTTP 429)"

    - alert: Acceso_Rutas_Sensibles_Denegado
      expr: sum(count_over_time({job="waf_access", status="403"} | json | uri=~"/(ftp|encryptionkeys|metrics|support/logs).*" [5m])) > 0
      labels: {severity: medium, owasp: "A02:2025", riesgo: "R12,R17", fuente: waf}
      annotations:
        summary: "Intentos de acceso a rutas sensibles bloqueadas (listados, /metrics, claves)"

    - alert: API_Enumeracion_Objetos_PosibleBOLA
      expr: count(sum by (uri) (count_over_time({job="waf_access", status="200"} | json | uri=~"/rest/basket/[0-9]+" [5m]))) >= 2
      labels: {severity: high, owasp: "A01:2025 / API1:2023", riesgo: "R06", fuente: api-monitoring}
      annotations:
        summary: "Acceso a varias cestas distintas en 5 min (patrón de enumeración / BOLA)"
```

```
- alert: RASP_Ataque_Detectado
  expr: sum(count_over_time({job="docker", container="juice-hardened"} |~ "^Zen has (blocked|detected)" [5m])) > 0
  labels: {severity: critical, owasp: "A05:2025", riesgo: "R01,R02", fuente: rasp}
  annotations:
    summary: "El RASP (Aikido Zen) detectó o bloqueó un ataque dentro de la aplicación"

- alert: App_Errores_5xx
  expr: sum(count_over_time({job="waf_access"} | json | status=~"5.." [5m])) > 5
  labels: {severity: medium, owasp: "A10:2025", riesgo: "R18", fuente: api-monitoring}
  annotations:
    summary: "Tasa anómala de errores 5xx (posibles condiciones excepcionales mal gestionadas)"
```

Anexo D. Controles compensatorios detallados por riesgo

R01 — Inyección SQL en el login (bypass de autenticación)

- WAF ModSecurity + CRS 942xxx (bloqueo 403) *[preventivo; Verificado]* evidence/fase-6/defensa-completa/
- RASP Aikido Zen: bloqueo en el sink sqlite3.all *[preventivo; Verificado]* evidence/fase-6/rasp/03-bloqueo-sin-caída/
- Alerta SIEM WAF_InyeccionSQL_Bloqueada / RASP_Ataque_Detectado *[detectivo; Verificado]* evidence/fase-6/siem/reglas-estado.json
- Parche 01: consulta parametrizada *[eliminacion; Diseñado (diff validado)]* app-hardened/patches/01-sqli-login.patch

R02 — Inyección SQL UNION en búsqueda (extracción de tablas)

- WAF ModSecurity + CRS 942xxx (bloqueo 403) *[preventivo; Verificado]* evidence/fase-6/defensa-completa/
- RASP Aikido Zen: bloqueo en el sink sqlite3.all (query.q) *[preventivo; Verificado]* evidence/fase-6/rasp/03-bloqueo-sin-caída/
- Alerta SIEM WAF_InyeccionSQL_Bloqueada / RASP_Ataque_Detectado *[detectivo; Verificado]* evidence/fase-6/siem/reglas-estado.json
- Parche 02: consulta parametrizada *[eliminacion; Diseñado (diff validado)]* app-hardened/patches/02-sqli-search.patch

R03 — Clave privada JWT embebida en el código (forja de tokens)

- Parche 04: clave fuera del código (variable/secreto) *[eliminacion; Diseñado (diff validado)]* app-hardened/patches/04-clave-privada-embebida.patch
- Gestor de secretos / KMS en la arquitectura cloud (Fase 2) *[eliminacion; Propuesto]* infra/terraform/

Nota: Ningún control desplegado detecta un JWT forjado: el residual se mantiene hasta desplegar el parche 04.

R04 — Bibliotecas JWT obsoletas (algoritmos débiles)

- SCA en CI (npm audit, OSV, Grype) que alerta del componente *[detectivo; Verificado]* evidence/fase-3/sca/
- Actualizar jsonwebtoken/express-jwt y fijar algorithms RS256 *[eliminacion; Propuesto]* docs/fase-1/fase1-modelado-amenazas.md

Nota: Aceptación TEMPORAL solo en el laboratorio (actualizar rompe retos de Juice Shop); en producción la decision es Eliminar.

R05 — Contraseñas con MD5 sin sal

- Bloqueo de la vía principal de extracción de hashes (SQLi: WAF + RASP) *[preventivo; Verificado]* evidence/fase-6/defensa-completa/
- Alerta SIEM de inyeccion SQL *[detectivo; Verificado]* evidence/fase-6/siem/reglas-estado.json
- Parche 03: bcrypt (factor 12) *[eliminacion; Diseñado (diff validado)]* app-hardened/patches/03-md5-a-bcrypt.patch

R06 — BOLA/IDOR: lectura de recursos de otro usuario

• WAF: NO lo bloquea (A12 VULNERABLE a través del WAF) *[preventivo; NO efectivo (verificado)]* evidence/fase-6/defensa-completa/bola/

• Monitoreo de API: alerta API_Enumeracion_Objetos_PosibleBOLA *[detectivo; Verificado]* evidence/fase-6/siem/reglas-estado.json

• Parche 08: verificación de propietario (403) *[eliminacion; Diseñado (diff validado)]* app-hardened/patches/08-bola-cesta-propietario.patch

R07 — Asignación masiva de role=admin en el registro

• Parche virtual ModSecurity 100001 *[preventivo; Verificado]* evidence/fase-6/defensa-completa/

• Alerta SIEM WAF_ParcheVirtual_Activado *[detectivo; Verificado]* evidence/fase-6/siem/reglas-estado.json

• Parche 06: lista blanca de campos *[eliminacion; Diseñado (diff validado)]* app-hardened/patches/06-asignacion-masiva-registro.patch

R08 — Inyección NoSQL en reseñas (MarsDB)

• Rechazar operadores ($ne, $where...) en filtros *[eliminacion; Propuesto]* docs/fase-1/fase1-modelado-amenazas.md

Nota: El RASP solo cubre NoSQL de MongoDB (no MarsDB) y el CRS no se verifico en esta ruta: brecha documentada.

R09 — Ejecución de código via eval()/vm

• Contención: FS solo lectura, cap_drop ALL, no root, no-new-privileges *[contencion; Verificado]* evidence/fase-5/despues/runtime-hardening-inspect.txt

• Parche 05: eliminar eval() *[eliminacion; Diseñado (diff validado)]* app-hardened/patches/05-eval-userprofile.patch

R10 — XXE en la carga de XML

• Parser XML sin entidades externas ni DTD *[eliminacion; Propuesto]* app-hardened/patches/README.md

R11 — SSRF en la imagen de perfil por URL

• Lista blanca de destinos y filtrado de egreso *[preventivo; Propuesto]* app-hardened/patches/README.md

Nota: El RASP instrumenta node:http (protección SSRF) pero no se verifico en esta ruta; no reduce el residual.

R12 — Listado de directorios y archivos internos (/ftp, /encryptionkeys)

• nginx deny de rutas sensibles (403) *[preventivo; Verificado]* evidence/fase-6/defensa-completa/

• Alerta SIEM Acceso_Rutas_Sensibles_Denegado *[detectivo; Verificado]* evidence/fase-6/siem/reglas-estado.json

• Retirar serve-index y archivos internos del servidor web *[eliminacion; Propuesto]* app-hardened/patches/README.md

R13 — XSS (CSP debil, sin codificación de salida)

• CSP estricta (script-src 'self') y cabeceras en el WAF *[preventivo; Verificado]* evidence/fase-6/defensa-completa/a9-security-headers.txt

• Codificación de salida en el frontend *[eliminacion; Propuesto]* docs/fase-1/fase1-modelado-amenazas.md

R14 — CORS permisivo (ACAO *)

• WAF oculta Access-Control-Allow-Origin *[preventivo; Verificado]* evidence/fase-6/defensa-completa/a8-cors-headers.txt

• Parche 07: origen explicito *[eliminacion; Diseñado (diff validado)]* app-hardened/patches/07-cors-restringido.patch

R15 — Redirección abierta (lista blanca evadible)

• Comparación exacta de destinos permitidos *[eliminacion; Propuesto]* docs/fase-1/fase1-modelado-amenazas.md

R16 — Fuerza bruta en el login (sin limitación de intentos)

• Rate limiting nginx 5/min (HTTP 429) *[preventivo; Verificado]* evidence/fase-6/defensa-completa/a10-bruteforce-login.txt

• Alerta SIEM Login_FuerzaBruta_RateLimit *[detectivo; Verificado]* evidence/fase-6/siem/reglas-estado.json

R17 — /metrics expuesto sin autenticación

• nginx deny /metrics (403) *[preventivo; Verificado]* evidence/fase-6/defensa-completa/a6-metrics.txt

• Parche virtual ModSecurity 100002 *[preventivo; Verificado]* evidence/fase-6/siem/consultas-logql.jsonl

• Alerta SIEM Acceso_Rutas_Sensibles_Denegado *[detectivo; Verificado]* evidence/fase-6/siem/reglas-estado.json

R18 — Denegación de servicio por vm/ZIP (agotamiento de recursos)

• Límites de pids (200), memoria (1 GiB) y CPU (1.0) *[contencion; Verificado]* evidence/fase-5/despues/runtime-hardening-inspect.txt

R19 — Registro sin centralización ni alertas

• SIEM: Alloy -> Loki -> Grafana con 7 reglas de correlación *[eliminacion; Verificado]* evidence/fase-6/siem/

• Alertas activas verificadas (6/7 en firing durante las pruebas) *[detectivo; Verificado]* evidence/fase-6/siem/reglas-estado.json

R20 — Dependencias con CVE criticas (cadena de suministro)

• SCA en CI (npm audit, OSV, Grype, Trivy) en cada push *[detectivo; Verificado]* evidence/fase-3/sca/

• Actualizar dependencias (crypto-js, lodash, marsdb...) *[eliminacion; Propuesto]* docs/fase-5/fase5-contenedores-hardening.md

Nota: Aceptación TEMPORAL solo en el laboratorio (la actualización rompe retos); en producción: Eliminar.

R21 — Configuración insegura al desplegar la arquitectura cloud (AWS)

• Checkov sobre Terraform (144 passed / 0 failed) *[preventivo; Verificado]* evidence/fase-2/checkov-final/

• No desplegar sin aprobación de costos (sin terraform apply) *[evitacion; Verificado]* docs/AUDITORIA_FINAL_FASES_4_5.md

• Servicios gestionados (AWS WAFv2, KMS) y responsabilidad compartida *[transferencia; Propuesto]* infra/terraform/

R22 — RASP en modo bloqueo provoca la caída del proceso (auto-DoS)

• Node --unhandled-rejections=warn (proceso sin caídas, RestartCount 0) *[eliminacion; Verificado]* evidence/fase-6/rasp/03-bloqueo-sin-caída/rasp-bloqueos.log

Nota: Inherente medido: el primer bloqueo termino el proceso (evidence/fase-6/rasp/02-bloqueo-caída-del-proceso/). Residual: la petición bloqueada no recibe respuesta; el resto del servicio sigue operativo.

R23 — Exposición de datos personales (incumplimiento de protección de datos)

• Bloqueo de la extracción masiva por SQLi (WAF + RASP) *[preventivo; Verificado]* evidence/fase-6/defensa-completa/

• Detección SIEM (SQLi, enumeracion BOLA) *[detectivo; Verificado]* evidence/fase-6/siem/reglas-estado.json

• Póliza de ciberriesgo / cláusulas contractuales *[transferencia; Propuesto]* docs/fase-6/tratamiento-riesgo.md

Nota: La vía BOLA sigue abierta (R06): por eso el residual no baja más.

R24 — SIEM de un solo nodo (sin alta disponibilidad; agente con acceso al socket de Docker)

• Solo 127.0.0.1, socket de solo lectura, retención 30 dias, sin telemetría externa *[contencion; Verificado]* deploy/hardened/docker-compose.ops.yml

Nota: Aceptado para el laboratorio; en producción: cluster gestionado y driver de logs en lugar del socket.